Risk Model Design

what are insider threats?

Insider threats represent a unique cybersecurity challenge because they originate from within the organization's circle of trust. Whether driven by malicious intent—such as data theft and sabotage—or simple human error, these risks involve individuals with legitimate access to sensitive systems. Because these actors operate behind traditional security perimeters, their activities are notoriously difficult to detect and even harder to mitigate.

threat scenarios

1. Abnormal login behavior

user logs in at unusual times compared to normal work hours

Normal: their work shifts (ex: 9 am - 5 pm)

sus: 2:30 am login

why? this could be: compromised account, malicious intention, unauthorized access

2. Excess file access

user downloads/accesses unusually large number of files

normal: 10 files/day or what is normal behavior according to their job census

sus: 300 files in 1 hour

why? could be data theft

3. Unusual resource access

user accesses files out of their role

normal: developer accessing code files

abnormal: hr accessing developer databases

why? violation of leave privilege principle

4. Abnormal network activity

large or unusual data transfer

sus: uploading large number of flies externally;
connecting to unknown IPs

Scenario	Risk
Abnormal Login	Medium
File Access	High
Resource Access	High
Network activity	High

risk factors

we will give a score for each of the risk scenarios (4 currently)

- **Login Anomaly Score**
- **File Access Anomaly Score**
- **System Access Anomaly Score**
- **Network Anomaly Score**

🗣️ these values will come from Member 2's ML model

risk scoring formula

we are now going to combine all of these 3 risk factors into one final risk score. We use a weighted formula. Why? because not all behaviors are equally dangerous

$$base\ risk\ score = 0.16 * login\ anomaly + 0.28 * file\ access\ anomaly + 0.28 * system\ access\ anomaly + 0.28 * network\ anomaly$$

FINAL RISK SCORE

base risk score + role deviation factor + behavior deviation factor

risk level

Score Range	Risk Level	Meaning	Action
0.0 – 0.2	Very Low	Normal behavior	No action

Score Range	Risk Level	Meaning	Action
0.2 – 0.4	Low	Slight deviation	Monitor
0.4 – 0.6	Medium	Suspicious	Log & review
0.6 – 0.8	High	Likely threat	Alert SOC
0.8 – 1.0	Critical	Severe threat	Immediate response

alert conditions

when will the system trigger an alert?

instead of a basic rule to trigger alerts, we use multiple:

Rule 1 — Risk Alert

if `Medium (0.4–0.6)` → Log for review

if `High (0.6–0.8)` → Generate alert

if `Critical (>0.8)` → Immediate alert + escalation

Rule 2 — Sudden Behavior Change

If `anomaly score suddenly increases`

→ alert

Rule 3 — Critical Scenario Trigger

If `file anomaly > 0.9` (or any specific anomaly score is high)

→ alert even if total score is low

Sample output:

```
ALERT: High Risk User Detected

User: user205
Risk Score: 0.89

Reasons:
- abnormal login time
- excessive file downloads
- unauthorized system access
```

context aware logic

same action ≠ same risk for all users

example: if a developer accesses code, there's no risk but if a hr accesses code, this is risky.

Hence, we implement role and expected access patterns based risk logic to reduce false positives.

1. role based

compare user behavior with expected role behavior

example:

Role	Normal Behavior
Developer	Access code, servers
HR	Access employee records
Finance	Access financial data

risk score:

```
If action is outside user role → increase risk score by
 20% (TENTATIVE)
```

2. history

risk score:

```
sudden deviation from baseline/normal behavior -> increase
risk by
 10% (TENTATIVE)
```

Behavioral Baseline Deviation